SOURCE REVIEW / 2026.10

校园综合服务小程序完整源码分析报告

功能核验 • 代码质量 • 数据与权限 • 原论坛融合

715 文件	85 页面	240 路由声明	36 安装表
原始交付	5主包 + 80分包	静态计数，非测通数量	另有3张运行扩展表

核心判断

值得借鉴的是完整校园服务场景和运营动作；不能直接照搬的是账号、权限、匿名输出、并发状态和数据库契约。建议保留我们的四类论坛体系，在其上增量扩展校园服务。

源码包含实际业务、部分断点与演示页面。已定位18组重点问题，并为Cursor整理30项功能整合台账和54条验收要求。报告不把README宣传、页面数量或历史测试当成本轮上线证明。

对象：用户提供的《校园服务小程序完整版》及 yydsxwh/forum、Andyyyds 原论坛代码。

交付范围：参考源码上传 + 分析报告 + Cursor开发提示词。业务开发、测试联调及授权后的部署由Cursor执行。

文件来源保留；本地配置和历史预览已从上传副本排除。

版本 1.0 | 2026年10月28日 | 适用于本次源码快照

阅读导航

先读结论与原论坛基线，再按业务或问题编号跳转。PDF书签可直接进入各章；末章[Sxx]链接指向源码定位。

01 审查范围与阅读方式	03
02 我们的论坛：真实代码基线	04
03 源码架构与技术判断	05
04 页面结构与产品范围	06
05 拼车：实现最集中的业务	07
06 通用模块：14 个键与生活服务	08
07 讨论、匿名树洞与通讯	09
08 校园地图、校历与办事工具	10
09 图鉴、成就、食堂、题库与兼职	11
10 后台、信用与运营能力	12
11 数据库：36 张安装表与运行扩展	13
12 接口、配置与交付完整性	14
13 高优先级问题：权限与匿名	15
14 高优先级问题：登录与资料	16
15 核心业务缺陷：编辑、模式、并发	17
16 模型缺陷：状态、学校与审核	18
17 契约缺陷：绑定、令牌与假成功	19
18 工程缺口与质量边界	20
19 原论坛功能保留清单	21
20 功能映射与复用策略	22
21 目标数据与权限方案	23
22 实施顺序与工作量判断	24
23 验收、部署与本次交付边界	25
24 证据索引与交付文件	26

01 审查范围与阅读方式

这是一份以源码证据为基础的产品、架构与融合评估，适合用于决定怎么改、先修什么，以及给 Cursor 分配实施工作。

本次做了什么

对指定目录进行全量文件清点、声明页面完整性检查、相对 require 引用解析和关键格式密钥扫描；深读入口、路由、核心控制器、模型、SQL、前端 API、代表性页面和原论坛代码，交叉核对“页面 - 请求 - 控制器 - 数据库”链路。

检查项目	可确认的事实
源码规模	715 文件，7,179,961 字节；其中 213 个 JavaScript 文件。
声明页面	5 个主包页面 + 80 个分包页面，共 85 个；对应 JS/JSON/WXML/WXSS 文件均存在。
后端规模	27 个路由文件、26 个控制器文件、34 个模型目录 JS 文件；240 处 router 方法声明。
数据库	install.sql 定义 36 个不同表名；入口还创建 3 张扩展表，实际落库成功与否尚未运行验证。
上传副本	706 个原始文件，7,027,098 字节；另加来源清单。9 个本地配置/历史预览备份文件被排除。

结论的证据等级

“代码具备”表示找到相应页面或业务实现；“部分/断点”表示实现之间有明显不一致；“演示/说明”表示静态数据、toast 或办理指南；“未验证”表示需要运行环境、外部服务或真实账号才能判断。不要把以上等级转换成未经测量的完成率。

本次没有启动该后端、安装其依赖、连接数据库、发短信、访问真实用户数据、修改业务代码或部署。报告不是渗透测试、依赖漏洞扫描、性能压测或对每一行源码的形式化证明。确认静态缺陷不需要运行现网，但运行影响仍需 Cursor 在隔离环境验收。

代码位置均相对于 references/campus-service。正文 [Sxx] 可点击；证据索引在末章。数量统计不包含“接口已联调成功”的含义。

02 我们的论坛：真实代码基线

应在现有四类论坛体系上扩展校园服务。不能因为 forum/main 目前很少，就重建一个只有校园功能的新站。

仓库/分支	核查结果
forum / main	98485b63e354694965d74b9c533521cda0eed208；只有 README，注明代码在主站 packages/forum。
forum / 独立运行候选	cursor/andyyyds-forum-port-ec0d；ba723b4c1879d461f7f0a565c941c25fb5196f63；PR #1 为 Draft。
Andyyyds / 默认分支	Andyyyds20260901independentpackage；8c2ab6c4767f9dacc3a4c1b110fb53fe8fbbda1a。
本次逐文件比较	候选中 packages/forum 的 blob 与上述主站同路径文件一致；这只能说明该目录代码一致，不能证明生产切流或数据迁移已经完成。

已存在、必须保留

大学论坛、兴趣圈子、本地同城、单位机构；两级话题专区；高校目录和学校认证；公开/仅本校可见帖子；图文与视频、草稿、编辑和隐藏；赞、收藏、蹲后续与更新通知；多渠道分享；多校广播；我的论坛；运营公告与后台能力开关。

独立运行候选还有明确门槛

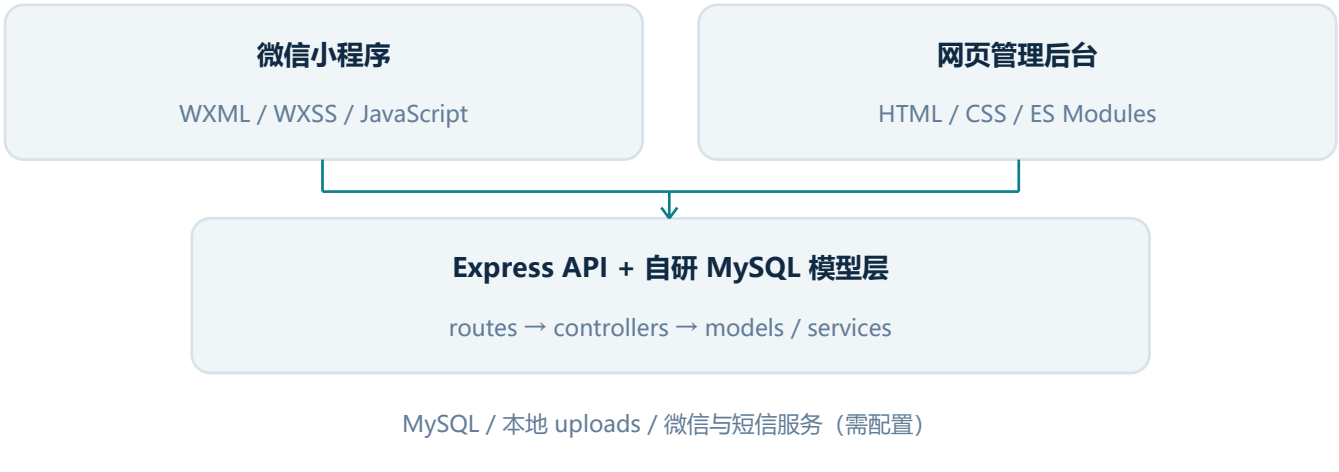
候选 README 和 SPLIT-READINESS 写明 Account OIDC、独立数据库、私有附件、生产数据映射、Platform/KKChat 权威来源与真实媒体上传等仍需验收。2026-10-20 的验证记录只覆盖当时隔离测试，明确没有证明真实 OIDC、生产迁移与部署。端口 4212 是候选，不是本报告确认的现网事实。

实施时重新核对最新提交与 PR。以真实运行代码为最终基线，保留当前作者 ID、原数据、附件和旧链接；不要强行切回本报告的快照。

远端依据：forum 的 main README、PR #1、docs/SPLIT-READINESS.md、docs/LOCAL-VALIDATION-20261020.json，以及主站 packages/forum。

03 源码架构与技术判断

这套源码是“原生微信小程序 + Express/MySQL 后端 + 原生网页管理后台”。它可以提供功能参考，但与我们的 Next.js 论坛不是可以直接拼接的同构项目。



层次	实际实现与含义
用户端	原生 Page/app、WXML/WXSS；主包与 subpkg 分包、共享页面基类、api.js REST 封装。
服务端	CommonJS + Express；JWT、mysql2、bcryptjs、multer/sharp、限流、日志等依赖。
数据层	自研 createModel/QueryBuilder 模拟 Mongoose 风格 API，但底层是 MySQL；不要误判为 MongoDB 项目。
管理端	backend/admin 下 HTML/CSS/ES Modules；模块化用户、内容、消息、统计等页面。
外部能力	微信登录/订阅消息、短信、图片资源域名等需要配置；存在开发或演示回退。

H5 宣传与代码不一致

README 写了“H5 移动端”，但 app.js 根路由明确注释“H5 前端已移除，仅保留小程序 + 后端 API”，根路径返回 JSON。本次没有发现与宣传相符、被主入口托管的完整 H5 用户端；遗留校历 HTML 不等于整个 H5 产品。网页用户端需要 Cursor 基于我们的论坛补建。 [S01] [S26] [S29]

技术版本来自交付 package.json/锁文件。本次未查询最新版本、执行 npm audit 或证明特定依赖存在公开漏洞。

04 页面结构与产品范围

源码的价值在于把校园讨论、办事和生活服务放进一组统一入口；其局限在于页面多、重复路径多，部分入口的深层动作尚未接通。

一级入口	源码体现的任务
首页	校园服务聚合、拼车/生活/指南等入口及公告运营位。
发布	拼车、求助、二手、失物、租赁、资料等快捷发布入口。
树洞	匿名内容浏览、分类与发帖/评论。
消息	私信、群聊、未读与通知入口，部分通知分类未完成。
我的	资料、信用、发布/参与/收藏、反馈投诉等，订单和设置有开发中提示。

85 个页面不能等同于 85 个已完成业务

页面声明四件套均齐全，说明交付的文件骨架比较完整；这并不代表每个按钮都发起真实请求。life 下若干页面保留本地列表，工具页主要是办理指引，成就提交还会用本地状态掩盖服务失败。页面检查和业务闭环验收必须分开。 [S02] [S19] [S22] [S27]

网页信息架构建议

保留原四类论坛入口。在大学分区内部增加“话题动态、校园服务、校园指南、消息、我的服务”的清晰分层。桌面支持学校/专区侧栏、列表筛选和详情信息区；手机保持同一内容结构，提供发布捷径和返回位置。不要把全部分包页面机械变成一级菜单。

重复与语义冲突需要收口

存在 pages 与 subpkg 的同类首页/消息/我的入口，以及普通 forum、匿名 treehole、bulletin、announcements 多套内容路径。发布中心把“分享资料”导向 print，也说明模块命名和用户任务并非一一对应。应先建路由和动作台账，再统一入口与数据来源。

05 拼车：实现最集中的业务

拼车是这份源码的核心，可借鉴其字段、列表、成员和通知流程；需要重写关键并发保存路径后，才适合承载真实业务。

环节	代码具备的能力 / 待补重点
发现	列表、关键词与起终点等筛选、排序、热门路线、地点和费用估算；估算不代表实际叫车或支付。
发布	时间、座位/人数、费用说明、联系方式、备注、偏好标签、图片和发布者快照。
参与	加入、重复加入检查、剩余座位检查、取消、发布者管理和结束拼车。
沟通	拼车业务群、成员与消息；业务群资格依赖创建者或仍为 joined 的参与者。
互动	收藏、通知、互评和信用分/次数统计。
边界	未见完整网约车调度、路线导航引擎或资金托管闭环；不得据此宣称具备这些能力。

源码中的主要断点

加入逻辑先读余位，再修改内存参与者数组和余位并保存。Carpool.save 随后更新主表、删除该拼车全部参与者再逐条插入，未用一个事务包裹。并发加入、取消或中途写入失败可能造成超卖、覆盖或成员丢失。它是明确的实现风险，不是本次压测观测到的现网事故。 [S04] [S05]

迁移后的合格闭环

发布 → 有效浏览 → 原子占座 → 业务群 → 取消释放/行程结束 → 真实参与双方评价 → 幂等信用事件。最后一个座位的并发竞争必须只有一个成功者；重试不能重复加分或多占座。结束、取消与评价资格由服务端状态机统一判断。

原始信用规则为初始 100、最高 110，部分完成/参与/好差评触发增减，低于 80 会触发临时封禁意图。数字只是当前代码默认值，整合时应配置化并先解决权限与流水问题。

06 通用模块：14 个键与生活服务

moduleController 的白名单实际有 14 个模块键。它们共用 module_posts、收藏、回复和部分接单逻辑；“共用 CRUD”并不等于每个行业流程都已完成。 [S03]

模块键	用户任务	整合重点
express / task	快递代取代寄 / 悬赏求助	交付时间地点、承接、完成确认、敏感取件信息与争议。
lost	丢失 / 拾到 / 找回	认领核验与隐私，不能只加一个联系按钮。
secondhand / rental	二手供求 / 闲置租赁	结构化价格、成色/租期、在售/预留/归还等状态。
substitute / print	互助代办 / 打印与资料	原文案含代课代跑；服务分类由站长配置，资料权限与交付状态独立。
yellowpage / charity	服务目录 / 公益捐赠	运营维护、投稿审核、分类联系、领取与推荐去重。
forum / bulletin	校园讨论 / 公告板	映射原 ForumPost/Zone 与公告体系，避免两套讨论权威。
parttime / questionbank / guide	兼职 / 资料题库 / 图鉴投稿	与独立参考表、后台和演示页面的数据路径统一。

共用能力

来源支持标题/正文、offer/find/info、价格及说明、联系方式、图片标签、地点、扩展 JSON、列表分页筛选、详情、编辑删除、收藏、回复、接单、完成和“我的”列表。创建与编辑、审核状态、学校范围和业务动作适用范围仍有缺口。

必须分离内容状态和交易状态

源码接单把所有模块统一写成 closed，再把承接人塞进 extra.taker；这会混淆“已承接”“完成”“下架”等含义。论坛和黄页也不应天然拥有同样的接单动作。建议公共内容记录承载展示与审核，独立服务实体承载人员、状态、金额和履约。 [S03] [S14]

README 的“12 模块”是宣传分组；14 是控制器白名单数量，两者统计口径不同，不能简单相减判断缺失。

07 讨论、匿名树洞与通讯

普通论坛应并入我们已有话题体系；匿名树洞保留独立的展示和审核语义；消息通过公司的通讯服务统一承载。

普通论坛与树洞的区别

来源普通 forum 用标签映射“课业、生活、竞赛、社交”等分类，底层仍是通用模块。树洞则有独立帖子、点赞、评论、匿名昵称、分类、热度/最新、审核及树洞管理路由。二者不应因为都能发文就混成同一个权限模型。 [S03] [S08] [S09]

能力	源码状态 / 判断
匿名内容	发帖待审、评论待审、审核通过/驳回、本人删除、点赞、分享、浏览计数具备代码；公开数据却保留用户关联ID，需要优先修复。
直接消息	文字/图片与表情相关页面、会话、未读、已读、撤回、用户备注等有实现；普通与增强消息路由并存。
陌生人控制	增强发送入口按关系与时间窗限额，并做敏感词过滤；必须核查普通发送入口是否同样执行。
拼车群	基于拼车成员资格提供群列表、群信息和消息；客户端5秒轮询，不是已证明的WebSocket实时架构。

整合到 KKChat 的边界

已读 KKChat 当前 README：服务端有 direct、messages、unread 接口，跨产品身份使用 accountSub，浏览器不能持服务 token。群能力还需查实际接口，不能假设直接消息接口即可支撑拼车群。旧消息迁移需映射作者、附件和业务关系，保持一个消息权威写入源。

匿名是对普通用户的展示承诺，后台追溯应限权限并审计。不能只把 UI 昵称改成“匿名”，却在 JSON、通知、图片路径或分享元数据中暴露真实用户关联。

08 校园地图、校历与办事工具

地图有实际的客户端定位与投影代码；校历和办事工具则更接近校园内容服务，不能误称为已接通学校官方办理系统。

模块	源码事实	需要的产品化
校园地图	手绘底图、2K/8K资源、缩放/拖动、GPS与像素投影、校园/宿舍POI、后台维护接口。	底图尺寸、投影矩阵、边界、POI按学校/校区配置；定位拒绝和离校状态有兜底。
校历	前端写死2026-2027两学期日期、周次与当日计算。	多校、多学年、学期与事件后台维护；不能每年改JS发版。
办事工具	挂失/充值/补卡、3类证明、贷款、医保、证件照、报销、奖学金、教务等说明页。	资料、流程、材料、FAQ、官方入口、联系人和导航可维护；真实办理接口另行接入。

地图不能只改一个校名

map.js 中校准参数、像素尺寸、经纬度边界和大量默认 POI 仍对应原学校；即使域名和 SCHOOL_NAME 已换成占位符，地图仍不是自动适配其他高校。上线前要逐校核实底图素材、坐标系、标定精度和位置授权。[S20]

办理指引不能伪装为办理结果

工具页含静态政策、金额和联系方式示例；导航/外链分支还有“即将上线”。校园卡充值页中的限额、到账时间或转账描述仅是来源文本，本报告没有确认它们是任何学校的现行政策。目标产品应标明学校、来源和更新时间，不向用户显示未经官方接口确认的充值/挂失成功。 [S27]

办事工具是需要运营维护的内容系统；本报告不对其中教育、医保、贷款等示例内容提供政策或法律结论。

09 图鉴、成就、食堂、题库与兼职

这些模块能显著扩展校园社区的留存场景，但各自成熟度不同，应按实际链路安排工作。

模块	实际实现与断点
图鉴与打卡	地标/组织/动物/植物/奖项/证书/限定等分类、条目和动态；打卡、收集进度、日历、排名、删除有后端。重复打卡代码覆盖图片/笔记并加次数，与“追加记录”文案不完全一致。 [S21]
成就认证	赛道、成就项、图片和说明提交、待审/通过/驳回/重提与后台审核有代码；前端接口失败后仍会模拟pending并显示成功。 [S19] [S30]
食堂与档口	食堂、档口分类搜索、评分和本人评价更新、聚合评分有代码；不是点餐配送系统。 [S24]
题库/资料	独立参考目录与通用模块发帖并存。当前证据支持资料目录/分享，不支持宣称已有完整刷题、自动判分和学习进度系统。 [S28]
兼职	life/parttime仍以本地演示列表和详情toast为主；通用模块支持parttime；后台另查parttime_jobs，交付SQL/启动迁移未找到此表。 [S22] [S23]

六个生活栏目需要独立验收

搭子、考试资料、好物、植物、打卡、兼职页面中可见静态列表和“详情页即将上线”动作。它们提供布局与需求线索，不能当作成熟模块直接上线。目标应补齐真实数据、详情、发布/投稿、搜索、审核和适用互动。

题库、资料和成就会接触版权材料或证书图片，必须按内容公开性和用户授权控制附件。与知识社区、课程或教务产品互联时，只复用已确认存在的能力，不凭入口名称假设付费权限已打通。

10 后台、信用与运营能力

管理后台覆盖面较广，适合借鉴“运营动作清单”；其身份与数据权限应并入我们的 Studio，而不是复制一套后台账号和独立树洞密码。

管理领域	来源代码覆盖
用户/管理员	搜索、资料、封禁/解封、重置/删除、信用调整、管理员权限。
内容与业务	拼车审核/撤下、模块帖子、公告、图鉴动态、成就审核、地图POI、兼职管理。
服务治理	投诉处理与申诉、反馈处理、结果评分、联系我们及回复、评价管理。
通讯与审计	会话/群聊记录、消息搜索/删除、管理员操作日志。
运营统计	概览、趋势、热门路线、增长、类型分布、统计快照/回填。
风控工具	敏感词增删、IP记录与封锁相关服务；定义工具不等于所有内容入口都已使用。

信用分：有规则，没有完整安全账本

源码通过用户字段直接存分数，并在通知中记录部分变更。普通用户信用调整接口缺权限校验，字段与SQL也有差异。正式方案应有不可随意覆写的事件流水、业务来源、幂等键、操作者、原因、撤销与申诉；普通用户只查询自己被允许查看的记录。 [S06] [S07]

统计和管理必须有学校范围

源项目更接近单校产品：学校大量作为文字或作者快照存在，通用模块列表与统计没有完整的学校租户约束。多校站长/运营人员应按角色和学校授权，后台查看私信、证书或投诉证据尤其需要最小权限与访问审计。

我们已有全站配置、论坛能力开关和学校认证后台，新增模块应接在同一管理体系中；同时保留原站长例外规则，避免“合并后台”改变既有用户权限。

11 数据库：36 张安装表与运行扩展

数据库结构比 README 的“21张表”更大。数据模型同时存在规范化关系、冗余快照和JSON扩展，需要迁移清单而不是整库导入。

领域	install.sql中的表
身份与风控（5）	users、admins、sms_codes、sensitive_words、ip_records
拼车与评价（4）	carpools、carpool_participants、favorites、reviews
消息、治理、运营（9）	messages、notifications、complaints、complaint_timeline、feedbacks、announcements、contact_messages、operation_logs、daily_stats
通用内容（3）	module_posts、module_favorites、module_replies
食堂（3）	canteens、canteen_stalls、stall_reviews
树洞（3）	treehole_posts、treehole_likes、treehole_comments
地图/推荐（2）	map_pois、hot_routes
目录/图鉴/成就（7）	yellowpages、questionbanks、guide_categories、guide_items、achievement_tracks、achievement_items、user_achievements

入口中的额外变更

app.js 启动时尝试给 users 加 wechat_id/qq/email，并建 guide_checkins、carpool_tag_options、guide_feed 三表。成功时是安装脚本36表之外的3表；本次没有运行并确认它们落库成功。启动异步迁移、吞重复字段异常不能替代统一迁移版本管理。 [S01] [S15]

已确认的数据契约差异

通用发布写 creator_userCode，但 module_posts 建表缺列；兼职后台用 parttime_jobs，但交付SQL和入口迁移没有建它；业务使用 banExpiresAt，users 的交付列是 banUntil。新增列名、状态和类型应统一到单一模型/迁移来源，分别测试空库及旧库升级。 [S03] [S15] [S16] [S23]

36个表名已按领域完整列出。计数依据是CREATE TABLE语句去重，不是运行中的SHOW TABLES结果。

12 接口、配置与交付完整性

相对引用和页面文件齐全是积极信号；交付文档、运行脚本与实际接口契约仍有不一致，不能据此认定拿到即可上线。

核验点	静态结果
相对require	扫描到的相对 require 引用未发现缺目标；不覆盖动态拼接、第三方包解析和运行期权限。
API数量	240处router方法声明，含管理端和多套消息/内容路径；不代表240个独立且已测试的端到端接口。
环境与密钥	源码含本地.env；上传排除它及两份project.private.config.json，保留.env.example。有限格式扫描未发现私钥/GitHub token/指定云key/JWT字面量，不等于证明完全无敏感信息。
缺失说明项	README列出的deploy-achievement.sh、deploy-treehole.sh未在交付目录找到；package.json seed指向的src/seed.js也不存在。
保留的文档	README、开发/部署/占位符说明、API文档等存在，但应视为历史线索，用代码验证。

版本与外部配置

生产域名、学校信息、微信凭证、短信、JWT、数据库、订阅模板和资源地址均需正确配置。不能只全文替换DOMAIN：生产模拟短信、树洞管理配置、地图标定和数据模式都需要专门处理。 [S11] [S20] [S26] [S29]

交付描述存在滞后

README 的表数、模块数和 H5 描述与代码不同。目录内旧兼职诊断报告声称某些API问题已修复、提到NestJS，但当前是Express且前台仍有静态演示路径。因此“文档写已修复”不能作为验收证据。

原上传压缩包没有一并公开：它含本地配置。逐文件上传能保留可读源码，同时避免把已排除文件藏在ZIP里重新带出去。

13 高优先级问题：权限与匿名

R01-R03 属于发布前必须处理的问题。它们来自明确代码路径，影响范围应在隔离环境复现；本报告没有对线上账号做验证。

R01 普通用户可以触达信用调整逻辑

routes/user.js 的整个用户路由只要求 authenticate；/credit直接进入updateCredit。控制器接受目标userId和score，没有管理员或业务服务权限校验，还可触发低分封禁意图。普通登录不等于可以修改任意用户的信用。 [S06] [S07]

修复：只开放给授权后台/服务，使用业务事件和信用流水；服务端核验操作者、目标、来源和幂等。验收：普通用户对自己/他人改分均被拒绝，合法处理有操作日志，低分封禁不能误伤。

R02 匿名公开响应包含真实关联键

TreeholePost.formatPost从完整行复制，保留user_id/user_id_code，并新增userId/userIdCode；评论列表也返回userId和userIdCode。匿名昵称没有切断身份关联，这些标识可能与用户搜索或其他公开接口联结。 [S09]

修复：公开DTO白名单与独立匿名标识；真实归属只给受权审核员，并审计读取。验收应覆盖列表、详情、评论、分享、通知和附件元数据，不能只检查页面肉眼是否显示真实姓名。

R03 待审树洞能从详情绕过公开列表过滤

公开列表筛status>=1，详情却查询status>=0，且没有对待审记录增加作者/管理员判断。列表不显示并不代表详情不可访问。 [S08]

修复：统一审核可见性策略，作者/审核员走明确权限路径；未授权者在详情、评论、分享和附件上得到一致拒绝，已发布/下架变化及时生效。

14 高优先级问题：登录与资料

生产环境的安全降级必须“明确不可用”；不能因外部配置缺失而放宽身份验证，也不能把数据库完整用户对象直接发给前端。

R04 生产短信配置为空/mock时回传验证码

authController.sendCode只有在production且短信配置非空、非mock时走真实发送分支；其他情况把code放进响应。这包括某些生产误配置情形，不能称为仅开发环境可达。 [S11]

修复：生产缺有效短信配置时拒绝，验证码只经受支持服务发出；日志/响应/监控不得泄漏。登录、手机号绑定及发送限额一起验收。

R05 树洞管理缺安全配置时只打印警告

TREEHOLE_ADMIN_PASSWORD缺失时设空串并警告，但登录和令牌生成/验证代码仍继续，未见统一禁用路由或强制启动失败。这与注释“将不可用”的保证不一致。 [S10]

修复：并入统一后台鉴权和权限体系，取消独立共享密码；配置缺失时明确不可用。不要保留空配置可继续处理管理认证的路径。

R06 私信会话返回完整用户对象

messageController.getConversations把User.findById结果直接放进otherUser；底层查询使用SELECT *，rowToObject未做敏感字段白名单，User模型也没有默认JSON脱敏。若行中存在密码散列、手机号或会话字段，响应结构可能带出。 [S12] [S13] [S16]

修复：统一公开资料DTO，只给ID/昵称/头像及必要业务标识；不得把带方法的模型对象当可公开数据。使用有敏感测试字段的两名合成用户检查真实JSON响应，而不是只检查UI显示。

没有记录或公开任何实际用户密码、token或数据库内容。问题描述仅用于用户获授权的源码修复。

15 核心业务缺陷：编辑、模式、并发

R07-R09 会直接阻断功能或破坏一致性，应和权限修复一起优先完成。

R07 通用帖子编辑引用未定义变量

moduleController.update解构的请求字段没有summary，后面却执行if(summary !== undefined)。在该路径没有同名局部/全局定义的正常运行条件下，会抛ReferenceError，后续更新不会完成。 [S03]

修复应使创建/编辑共享校验和摘要生成规则。验收要真实编辑保存并重新读取，覆盖部分字段更新，不用“页面能打开”替代。

R08 代码字段与交付SQL不匹配

creator_userCode缺列、parttime_jobs缺建表、banExpiresAt/banUntil不一致不是同一个问题的不同表述，而是多个契约断点。新空库可能在相关写入/查询时失败，具体行为依赖数据库实际结构。本次不能凭源码判断旧部署是否手工补过这些字段。 [S03] [S15] [S16] [S23]

修复：单一迁移、字段白名单、版本化增量SQL；对空库和已有用户/帖子/附件的旧库分别验收。错误必须可见，不用捕获异常后继续显示成功。

R09 拼车多步保存没有事务保护

加入逻辑先检查再写；保存主表和参与者不是原子事务，参与者还会整批删除再插入。竞争和异常会影响余位、成员和统计一致性。 [S04] [S05]

修复：原子条件更新/事务锁、参与唯一约束、幂等键和失败回滚；避免保存整个成员数组覆盖别人更新。最后一座竞争、同时取消/加入、中途故障和重试都应测试。

这些是静态可定位问题。未运行程序意味着本报告没有出具“所有创建/编辑接口都失败”的统计结论。

16 模型缺陷：状态、学校与审核

R10-R12 说明这套单校源码不能直接扩展成我们的多类、多校论坛。展示层筛选无法代替服务端的数据边界。

R10 所有通用模块共用接单与closed状态

takePost只按模块白名单和帖子状态判断，统一写closed及extra.taker，没有明确的业务适用模块/原子承接条件。closed既可能表示结束，也被当作已承接，完成又写resolved。 [S03]

目标：任务有承接/履约/确认状态，租赁有交付/归还，二手有预留/售出，失物有认领。普通讨论、黄页、资料目录不应因为共用表就获得接单动作。

R11 学校是快照，不是完整租户边界

通用模块列表不绑定school/university授权范围，creator_school主要是发布者快照。校园地图、食堂和目录等多处也按单校数据组织。若直接并入多校论坛，前台切换学校无法阻止跨校直接API访问。 [S03] [S14]

目标：业务明确归属space/university/campus，服务端从授权上下文限定创建、查询、详情、互动、附件、管理、搜索、通知和统计。保留同城/圈子/单位的原权限，不把所有用户强制变成学生。

R12 通用内容审核字段没有全链路执行

module_posts有auditStatus，但getList/getDetail的查询未见对应批准状态过滤；详情按ID直接取行，下架/未审内容需要统一策略。后台能审核不等于公开读接口遵守审核。 [S14] [S15]

目标：内容状态、审核状态与业务状态分离；公开读只返回有权内容，作者和审核员走专门路径。附件和通知摘要使用相同可见性规则，禁止“页面删入口、旧链接仍能读”。

17 契约缺陷：绑定、令牌与假成功

R13-R15 容易造成用户看到“成功”，系统却没有安全、持久且可审计的真实状态。

R13 手机号绑定前后端字段不一致

api.bindPhone发送phone+code，绑定页发送验证码却仅演示；后端bindPhone要求phone+password，未验证验证码，就设置isVerified并保存密码。User.save没有像create那样对新密码散列。当前前端可能因缺password失败；若客户端按后端要求传入，仍存在控制权验证和密码写入风险。 [S16] [S17]

目标：统一到Account绑定能力，校验手机号控制权；密码变更如确实需要，走专用验证和散列流程。填写学校和绑定手机都不能自动成为学校认证通过。

R14 访问与刷新令牌用途未隔离

authenticate只验相同JWT密钥和userId，没有拒绝type=refresh；生成刷新令牌时又包含同样userId。因此只凭当前代码无法形成严格的令牌用途边界。 [S18]

目标：按Account现有协议验证用途、签发者、受众和过期/撤销；普通业务接口拒绝刷新令牌。避免把参考登录栈复制成第二套账号中心。

R15 成就接口失败后仍显示提交成功

achievement-detail中上传/提交失败可转入本地模拟，把缓存写pending并提示“提交成功，等待审核”。用户可能以为证书已进入审核，服务器却没有记录。 [S19]

目标：失败明确提示、保留草稿并允许重试；只有服务端成功响应后变更已提交状态。更换设备或账号后状态仍应由服务器返回，不能依赖本地缓存冒充权威。

18 工程缺口与质量边界

R16-R18 是把源码参考转成可运维产品时不可省略的工作；源码当前没有提供足以证明上线质量的测试证据。

R16 演示、占位和历史说明混杂

生活页详情toast、工具导航/外链占位、订单/设置/评论通知开发中，以及旧兼职修复报告与当前代码不一致，都需要逐入口列账。不能用“原源码就这样”跳过用户要求的功能。演示数据应留在隔离样例，生产使用真实数据和清晰空态。 [S19] [S22] [S27]

R17 上传类型和私有资源需要重新设计

上传按原始文件名保留扩展名，实际编码却统一JPEG，可能产生内容类型与后缀不一致；最多9张原图可先进入内存，需限制总量和并发。uploads作为公共静态目录，不适合直接放学生证明、成就证书或投诉证据。 [S25] [S01]

我们原论坛支持30项图片/视频，不能被参考上传能力降级。目标存储要有所有者、业务归属、可见性、签名/鉴权访问、孤儿清理和恢复验证。

R18 迁移与测试不完整

backend/package.json没有test脚本，seed指向缺失文件；install.sql含DROP TABLE并明确警告重复执行会清空同名表。启动临时迁移、异步统计和部署文档不能代替版本化迁移、备份恢复、健康/就绪和回滚。 [S01] [S15] [S26]

额外建议核对

评价注释称“已结束”，实际创建流程未见相应状态检查；回复点赞和公益推荐可反复加数；重复打卡覆盖历史；ban状态字段和时区序列化需要统一。敏感词和IP服务的存在不证明所有入口都接入。应以真实业务/越权/并发/失败场景测试补齐，不机械增加镜像实现的测试。

19 原论坛功能保留清单

原论坛功能更多、身份边界也更成熟。校园源码应提供扩展需求和实现参考，而不是成为替换主干的理由。

保留项	不可回退的行为
四类分区	大学、兴趣圈子、同城、单位机构及原slug/入口。
两级专区	父子专区、排序、启停和后台编辑。
学校与成员	高校目录、加入、旧成员兼容、本科/研究生认证和审核。
访问控制	公开/仅本校认证可见，作者和站长例外，私有认证证明。
内容与媒体	图文/视频、最多30媒体、4000字正文、草稿、编辑、删除与隐藏。
发现与互动	搜索、筛选、评论、赞、收藏、WATCH、后续通知与我的列表。
地点与分享	地图选点、地点链接、复制/系统/二维码及各渠道实际支持的分享。
多校广播	独立副本、专区对齐、跳过原因与各校互动隔离。
运营管理	普通成员能力开关、站长例外、公告主题/动画/媒体/链接。
公共边界	原作者、Account映射、附件、旧数据、主站入口和国际化。

验收的关键不是“新功能更多”

增量后旧用户仍能找到自己的草稿、收藏和蹲后续；旧本校限定帖仍只对合格用户可见；原普通圈子用户不会被学生认证拦住；旧附件和分享链接不失效。这些回归必须独立于校园服务新增用例执行。

依据：packages/forum/lib、api、components、routes 与候选 Prisma schema；原附件和生产迁移本次未访问验证。

20 功能映射与复用策略

整合重点是统一业务权威和权限规则，而不是把另一套Express后端挂在我们网站旁边就宣布完成。

参考能力	目标承载方式	原因
普通讨论/回复/收藏	复用ForumPost/Comment/Action/Zone	原论坛已有更完整分区、媒体和校内可见规则。
拼车/任务/市场/租赁	新增结构化业务实体与公共内容摘要	人员、价格、状态和并发需要强约束，不能只靠extra JSON。
树洞	独立匿名展示与审核模型	真实身份和匿名标识分离，审计追溯独立授权。
目录/图鉴/校历/工具	校园内容与配置中心	多校运营、版本与来源可维护，避免写死学校事实。
账号与认证	Account身份 + 论坛学校资质	稳定accountSub映射，保留已有学校认证，不另造密码体系。
私信与业务群	经核实能力后接KKChat	一个消息权威；群成员与业务生命周期同步。
附件与通知	现有存储/通知适配层	公开与私有内容不能同用公开静态资源。
支付意图	仅接已验证可用的统一能力	参考价格/押金不是支付闭环，不能模拟成功。

公共平台不能凭计划当作已上线

已核查Platform README标注多个模块NOT_DEPLOYED，且明确不要对其生产自动部署。论坛实施应核实当前可用接口，保留适配和明确不可用状态；不能为完成论坛任务擅自发布整个公共平台，也不能凭假响应冒充已接通。

知识社区/课程/教务联动作为相关业务入口处理；实际能力、会员/资料权限和服务身份需再验证，禁止通过论坛摘要、搜索或附件绕过原产品权限。

21 目标数据与权限方案

建议继续使用论坛现有技术栈与独立产品边界，按业务新增模型和API；是否迁移数据库应由真实部署、并发与运维证据决定。

数据最小结构

每项校园业务明确spaceId/universityId/campusId、作者本地ID与accountSub映射、内容/审核/业务三类状态、可见性、时间、结构化业务字段、附件归属和审计。金额使用统一最小货币单位；多步变更用事务、唯一约束和幂等键。

角色	允许范围
访客	仅公开且已发布内容；不返回联系方式、待审记录或私有附件。
登录成员	按原论坛和学校范围发帖/互动；只能改自己的合法内容。
已认证校内成员	在本人有资格的学校读取校内限定内容，按模块规则参与业务。
业务双方	按状态获取必要联系方式、履约信息；不能看其他人的任务或私信。
学校运营/审核	仅授权学校和模块，查看必要证据，保留操作与访问审计。
站长/管理员	保留原站长语义，敏感数据仍受职责与审计约束。
内部服务	服务凭证和actor双重核实，按scope执行，浏览器无服务密钥。

关键状态机

任务：可接单→承接→履约→待确认→完成，另有取消/争议；拼车：发布/满员/截止/结束/取消；二手：在售/预留/售出/下架；租赁：预订/交付/租用/归还/争议；成就：待审/通过/驳回/重提。每条转移约束操作者和前置条件。

以上是目标设计建议，不是声称源代码已经实现这些全部状态。完整实施要求在配套Cursor MD中列出。

22 实施顺序与工作量判断

建议按风险和真实依赖拆阶段，持续交付可验证闭环。静态源码无法可靠给出准确工期或报价，本报告不编造天数。

阶段	工作与出口
0 核基线	复核最新分支/PR/现网来源，建立原功能基线与C01-C30功能台账；确认素材来源和数据模型。
1 安全基础	修R01-R18中身份/权限/隐私/字段问题，建立多校范围、存储、审核与原论坛回归。
2 主闭环	拼车、任务/快递/代办/打印、市场租赁、失物公益、消息、评价信用与投诉。
3 校园运营	黄页题库、图鉴成就、地图食堂校历、办事工具、生活栏目和完整后台，消除演示。
4 验证发布	多库联调、数据附件试迁移、并发/权限/失败恢复、预发、授权生产切流和回滚。

相对工作量

较低：静态指南/校历/黄页的配置化、已有专区分类映射。中等：多校目录、图鉴、食堂、成就、后台审核及通知。较高：拼车占座、任务状态、租赁争议、信用账本、匿名隐私、KKChat/Account迁移和旧生产数据切流。前两类也受多校权限和存储基础影响，不应孤立估算。

Cursor应交付什么

真实代码与逐项功能状态、字段/API/权限契约、迁移和回滚说明、R01-R18修复证据、54项验收清单结果、页面/预发验证与提交/PR。代码完成、测试通过、联调、预发、生产切流分别记录，不能互相替代。

缺外部接口或凭证时，继续完成不依赖它的内容，准确列出阻塞项；不能以模拟成功、空页面、只留待办或单纯输出架构方案代替目标。

23 验收、部署与本次交付边界

用户授权本次上传和分析，业务开发与上线交给Cursor。本报告及上传资料没有修改原论坛或部署环境。

必须有证据的验收组

组别	代表场景
原论坛回归	四类分区、校内限定、认证私有证明、30媒体/视频、草稿、互动/WATCH、分享、多校广播和后台开关。
校园服务	发布→承接→完成/取消/争议；最后一座竞争、同时接单、实际参与评价、信用去重、匿名审核与通知。
数据安全	跨校访问、普通用户改分、完整用户对象、待审详情/附件、刷新令牌、生产模拟配置。
工程运行	空库/旧库迁移、附件恢复、故障注入、分页与上传限额、弱网、桌面/手机/微信内。
上线证据	备份/增量/校验/回滚；真实OIDC、服务凭证边界、进程与反代、健康/就绪及当前提交。

上传范围

参考目录保留706个原始文件，文件内容未作业务修复；排除.env、两份私有项目配置和6个历史预览/备份。逐文件SHA-256及排除理由在IMPORT-MANIFEST.json；原始ZIP不上传，防止重新包含被排除的配置。

授权与素材

源README称“商业交付源码”，未提供通用开源许可；本次上传不改变原协议。二次开发、公开分发及地图/校徽/素材的使用范围应按用户取得的实际授权处理，不能把“能拿到源码”写成“已确认全部素材开源”。[S29]

本机所有新报告、临时渲染、上传副本和分析清单均放D盘任务目录；E盘原件只读。未中断编辑文档、当前聊天或VPN，未安装软件、修改业务代码、导入SQL或发布站点。

24 证据索引与交付文件

以下定位用于复核本报告的关键事实。路径与行号对应本次导入的原始文件；今后若修改源码，应使用提交快照重新定位。

证据	源码位置
[S01] 入口与挂载	backend/src/app.js:48
[S02] 小程序页面声明	mini-program/miniprogram/app.json:1
[S03] 通用模块控制器	backend/src/controllers/moduleController.js:15
[S04] 拼车加入逻辑	backend/src/controllers/carpoolController.js:384
[S05] 拼车保存参与者	backend/src/models/Carpool.js:503
[S06] 信用分写入	backend/src/controllers/userController.js:239
[S07] 用户路由认证范围	backend/src/routes/user.js:6
[S08] 树洞详情与输出模型	backend/src/models/TreeholePost.js:102
[S09] 树洞用户标识输出	backend/src/models/TreeholePost.js:296
[S10] 树洞管理认证	backend/src/routes/treeholeAdmin.js:7
[S11] 验证码发送条件	backend/src/controllers/authController.js:498
[S12] 私信用户对象	backend/src/controllers/messageController.js:16
[S13] 自研查询器字段转换	backend/src/models/mysql.js:124
[S14] 模块列表与详情	backend/src/models/ModulePost.js:237
[S15] 建表安装脚本	backend/install.sql:1
[S16] 用户保存逻辑	backend/src/models/User.js:179
[S17] 客户端绑定契约	mini-program/miniprogram/utils/api.js:292
[S18] 登录中间件	backend/src/middleware/auth.js:14
[S19] 成就失败本地成功兜底	mini-program/miniprogram/subpkg/achievement-detail/achievement-detail.js:267
[S20] 地图校准与资源	mini-program/miniprogram/subpkg/map/map.js:89

证据	源码位置
[S21] 图鉴打卡	backend/src/controllers/guideCheckinController.js:73
[S22] 兼职静态页面	mini-program/miniprogram/subpkg/life/parttime/parttime.js:151
[S23] 兼职后台数据源	backend/src/controllers/parttimeAdminController.js:1
[S24] 食堂评价	backend/src/controllers/foodController.js:56
[S25] 图片上传	backend/src/routes/upload.js:25
[S26] 项目依赖与脚本	backend/package.json:1
[S27] 校园卡办理指引	mini-program/miniprogram/subpkg/tools/card-recharge/card-recharge.js:1
[S28] 资料只读路由	backend/src/routes/reference.js:1
[S29] 源项目说明和授权	README.md:1
[S30] 成就审核API	backend/src/controllers/achievementController.js:179

远端基线：forum PR #1（Draft）；forum/main及cursor/andyyyds-forum-port-ec0d；Andyyyds/Andyyyds20260901independentpackage；KKChat/main README；Platform/main README。均通过连接的GitHub工具读取，未推断真实生产状态。

配套交付：Cursor-论坛融合开发提示词.md（C01-C30、R01-R18、54条验收）；references/campus-service/IMPORT-MANIFEST.json。此PDF为阅读与评估主件，MD为实施指令。